

RAPORT Z AUDYTU BEZPIECZEŃSTWA

Audyt bezpieczeństwa własnego serwera MediaWiki

Audyt white-box własnej infrastruktury, wykonany przed migracją MediaWiki

Autor: Krzysztof Pieczka

Data: 07.10.2026

Typ: white-box (pełny dostęp do kodu i systemu)

4

HIGH

9

MEDIUM

8

LOW

8

INFO

Zakres: konfiguracja i rdzeń MediaWiki, rozszerzenia, własny kod PHP, serwis uploadu (Flask), warstwa serwera (Apache, PHP, uprawnienia) oraz ekspozycja origin względem Cloudflare. Dane osobowe i identyfikatory serwisu zanonimizowano.

Audyt własnego systemu przeprowadzony przed migracją MediaWiki na nowy serwer. Charakter white-box.

Zakres: konfiguracja MediaWiki, MediaWiki core i rozszerzenia, własny kod PHP w katalogu web, serwis uploadu we Flasku (formularz), warstwa serwera (Apache, PHP, uprawnienia), ekspozycja origin względem Cloudflare.

Findingi weryfikowane empirycznie tam gdzie to możliwe (PoC). Część wstępnych hipotez odrzucono po weryfikacji: RCE przez upload wykluczone kodem, podejrzenie zepsutego rate-limitu obalone (dane produkcyjne pokazują realne IP klientów).

Ważność: HIGH / MEDIUM / LOW / INFO.

1. Środowisko

Komponent	Wersja	Uwaga
MediaWiki	1.43.0	najstarszy release gałęzi 1.43
PHP	8.3.6 (apache2handler)	Apache + mod_php
Apache	2.4.58 (Ubuntu), build 2026-07-06	świeżo patchowany
Baza	MySQL 8.0.46-0ubuntu0.24.04.4	Ubuntu 24.04 LTS
ICU	74.2	
Skórki	Vector (2022) + Citizen (third-party)	Citizen wymaga osobnego pobrania

Entry pointy: /wiki/\$1, /, index.php, api.php, rest.php.

Spis treści

ukryj

Początek

Zainstalowane oprogramowanie

Adresy URL punktów wejścia

Zainstalowane skórki

Zainstalowane rozszerzenia

Strony specjalne

Edytory

Haki analizatora składni (ang. parser hooks)

Ochrona przed spamem

Pozostałe

Zainstalowane biblioteki

Zainstalowane biblioteki po stronie serwera

Zainstalowane biblioteki po stronie klienta

Znaczniki parsera pochodzące z rozszerzeń

Funkcje parsera

Wersja oprogramowania

Narzędzia

Licencja MediaWiki

Ta wiki korzysta z oprogramowania MediaWiki, copyright © 2001-2026 Magnus Manske, Brooke Vibber, Lee Daniel Crocker, Tim Starling, Erik Möller, Gabriel Wicke, /Evar Arnfrjörð Bjarmason, Niklas Laxström, Domas Mituzas, Rob Church, Yuri Astrakhan, Aryeh Gregor, Aaron Schulz, Andrew Garrett, Raimond Spekking, Alexandre Emsenhuber, Siebrand Mazeland, Chad Horohoe, Roan Kattouw, Trevor Parscal, Bryan Tong Minh, Sam Reed, Victor Vasiliev, Rotem Liss, Platonides, Antoine Musso, Timo Tijhof, Daniel Kinzler, Jeroen De Dauw, Brad Jorsch, Bartosz Dziewoński, Ed Sanders, Moriel Schottlender, Kunal Mehta, James D. Forrester, Brian Wolff, Adam Shorland, DannyS712, Ori Livneh, Max Semenik, Amir Sarabadani, Derk-Jan Hartman, Petr Pchelko, inni oraz tłumacze translatewiki.net.

MediaWiki jest wolnym oprogramowaniem – możesz je dystrybuować i modyfikować zgodnie z warunkami licencji GNU General Public License opublikowanej przez Free Software Foundation w wersji 2 tej licencji lub (jeśli wolisz) dowolnej późniejszej.

MediaWiki jest dystrybuowane w nadziei, że okaże się użyteczne ale BEZ JAKIEJKOLWIEK GWARANCJI – nawet bez domyślnej gwarancji PRZYDATNOŚCI HANDLOWEJ lub PRZYDATNOŚCI DO OKREŚLONYCH ZASTOSOWAŃ. Więcej szczegółów znajdziesz w treści licencji GNU General Public License.

Powinienes otrzymać kopię licencji GNU General Public License wraz z niniejszym oprogramowaniem. Jeśli tak się nie stało, napisz do Free Software Foundation, Inc, 51 Franklin Street, Fifth Floor , Boston, MA 02110-1301, USA lub przeczytaj licencję w Internecie.

Zainstalowane oprogramowanie

Nazwa	Wersja
MediaWiki	1.43.0
PHP	8.3.6 (apache2handler)
ICU	74.2
MySQL	8.0.46-0ubuntu0.24.04.4

Wygląd

ukryj

Tekst

Mały

Normalny

Duży

Na tej stronie zawsze używany jest mały rozmiar czcionki

Szerokość

Normalna

Duża

2. MediaWiki core / wersja

2.1 **HIGH** - Nieaktualny MediaWiki, brak około dziewięciu wydań poprawek bezpieczeństwa

Zainstalowana wersja 1.43.0, pierwsze wydanie gałęzi. Aktualne stabilne wydanie gałęzi to 1.43.9 (29.06.2026). Brak wszystkich poprawek z 1.43.1 do 1.43.9.

Przykładowe CVE załatane po 1.43.0: rodzina XSS/escaping z release notes gałęzi 1.43 (m.in. CVE-2025-61636 - nieescape'owany content w rawElement; w tej serii wydań łatano też wstrzykiwanie komunikatów jako HTML i wyciek ukrytych nazw użytkowników), a z 1.43.9 m.in. CVE-2026-58026 (wyciek informacji w Parser.php), CVE-2026-58024 (wyciek informacji w ApiUserRights.php), CVE-2026-58037 (XSS w LogFormatter). Trackery wskazują też info-disclosure w Skin.php i OAuthAuth przed 1.43.7.

Ryzyko głównie stored/reflected XSS i wyciek metadanych. Częściowo mitygowane przez wyłączoną edycję anonimową i Turnstile na rejestracji, ale XSS przez treść dotyczy też zaufanych edytorów.

Rekomendacja: migracja rozwiązuje wprost, nowa instalacja z aktualnego tarballa. Nie przenosić core 1:1.

3. Konfiguracja (LocalSettings.php)

3.1 **MEDIUM** - display_errors na produkcji

```
ini_set('display_errors', 1);
```

Wyświetlanie błędów PHP użytkownikom na produkcji ujawnia ścieżki absolutne, wersje bibliotek, czasem fragmenty zapytań i stack trace. Rekomendacja: display_errors = 0 na produkcji, logowanie do pliku.

3.2 **LOW** - Spalone klucze ReCaptcha w komentarzach

Stare klucze ReCaptcha (site i secret) pozostawione zakomentowane. Zakomentowanie nie usuwa sekretu, zostaje w pliku i backupach. Usunąć fizycznie, zrotować po stronie dostawcy.

3.3 **INFO** - Sekrety w LocalSettings i higiena backupów

LocalSettings.php zawiera hasło bazy, wgSecretKey, wgUpgradeKey, wgTurnstileSecretKey. To po części natura MediaWiki (musi je czytać). Ryzyko realne gdy plik czytelny z weba lub w publicznym repo. Przy migracji regenerować wgSecretKey i wgUpgradeKey, nowe hasło bazy. Backupy i config trzymać poza publicznym repo write-upu, w publikacji maskować.

3.4 **MEDIUM** - Upload SVG (stored XSS)

wgFileExtensions zawiera svg. SVG to XML mogący nieść JavaScript, klasyczny wektor stored XSS przy serwowaniu inline. Zidentyfikowane z konfiguracji jako potencjalny wektor. Sanityzer SVG w MediaWiki (kod rdzenia, nie własny) jest aktywny, więc realna wykorzystywalność zależy od jego obejścia. Rekomendacja niezależna od testu: usunąć svg z dozwolonych rozszerzeń jeśli nieużywane, w przeciwnym razie wymusić Content-Disposition: attachment i CSP.

3.5 **MEDIUM** - ExternalData: potencjalny SSRF

```
$wgExternalDataAllowedProtocols = [ 'http', 'https' ];  
$wgExternalDataAllowedSources = [ 'wiki-api' => 'https://[REDACTED]/' ];
```

Rozszerzenie ExternalData 3.5 pobiera dane z zewnętrznych URLi. Jeśli cel żądania da się kontrolować przez treść strony, wektor SSRF. AllowedSources ogranicza dostęp. Zidentyfikowane z konfiguracji jako potencjalny wektor (kod third-party). Rekomendacja niezależna od testu: zawęzić protokoły i źródła do minimum, wyłączyć jeśli nieużywane.

3.6 **INFO** - Kontrole anti-spam po incydencie

Edycja anonimowa wyłączona, rejestracja i trigger captcha za Turnstile. Pozostałość po ataku bota, dobra kontrola, obniża powierzchnię części findingów XSS.

4. Rozszerzenia MediaWiki

Zebrane wersje: EmbedVideo 4.0.0 (2022), ExternalData 3.5, FlaggedRevs (git 07.2025), ConfirmEdit 1.6.0, WikiEditor 0.5.4, ParserFunctions 1.6.1, reszta bundlowana z core.

4.1 **MEDIUM** - EmbedVideo mocno nieaktualne

EmbedVideo 4.0.0 z 27.04.2022, około cztery lata bez aktualizacji, fork StarCitizenWiki. Rozszerzenie osadza zewnętrzną treść (URL wideo), przetwarza input. Brak przypisanego pojedynczego CVE dla 4.0.0, ale cztery lata poprawek niezaaplikowane, a klasa rozszerzenia to typowe pole XSS. Rekomendacja: pobrać aktualną wersję pod nowe MediaWiki, rozważyć rezygnację jeśli mało używane.

5. Własny kod PHP

5.1 **INFO** - latest-video.php i latest-video-orangutan.php: sprawdzone, czyste

Oba pobierają stały feed RSS YouTube (zahardkodowany channel_id), zwracają videoId w JSON. Zero danych wejściowych od użytkownika, brak SSRF/LFI/injection. XXE rozważone i niewykorzystywalne (PHP 8.3, encje zewnętrzne domyślnie wyłączone, źródło zaufane). latest-video.php ma poprawną higienę (cURL, weryfikacja SSL, timeout, fallback). latest-video-orangutan.php słabsza obsługa błędów, jakość kodu, nie luka.

6. Serwis uploadu Flask (formularz/app.py)

6.1 **HIGH** - Hardcoded hasło admina w kodzie

```
ADMIN_PASSWORD = "..."  
def check_auth(password):  
    return password == ADMIN_PASSWORD
```

Hasło do panelu admina w plaintext w źródle. Panel moderuje i kasuje zgłoszenia oraz pliki z dysku. check_auth weryfikuje wyłącznie hasło (nazwa użytkownika ignorowana), porównanie == nie constant-time (marginalne). W połączeniu z 6.10 hasło było publicznie do odczytania. Rekomendacja: sekret poza kodem (zmienna środowiskowa), hash zamiast plaintext, hmac.compare_digest, weryfikacja także nazwy użytkownika. Zrotować hasło niezależnie od migracji.

6.2 **INFO** - Rate limiting: sprawdzone, działa

Wstępna hipoteza (request.remote_addr widzi tylko IP proxy, więc rate limit nieskuteczny) obalona danymi: submissions.db i raporty GoAccess zawierają realne IP klientów, a kolumna ip pochodzi z request.remote_addr. Realny adres dociera do aplikacji (przywracany na poziomie WSGI, ProxyFix/X-Forwarded-For, bo mod_remoteip niezaładowany). Rate limit i Turnstile remoteip działają na realnym IP. Pozostaje tylko drobna słabość z 6.8.

6.3 **MEDIUM** - Upload: walidacja oparta o dane kontrolowane przez klienta

```
ext = original_name.rsplit('.', 1)[-1].lower() # nazwa od usera  
mime = file.mimetype # Content-Type z requestu
```

file.mimetype to nagłówek multipart kontrolowany przez atakującego, ext z nazwy pliku również. Brak weryfikacji magic bytes ani parsowania obrazu.

RCE przez Apache wykluczone kodem: plik zapisywany jako uuid4().ext z whitelisty, oryginalna nazwa wyrzucana, więc .php nie da się przemycić. Katalog jest jednak wykonywalny przez Apache, więc przyszła zmiana dopuszczająca dowolne rozszerzenie oznacza natychmiastowe RCE.

Pozostałe ryzyko: brak weryfikacji zawartości plus brak X-Content-Type-Options: nosniff na ścieżce uploadów daje pole na content-sniffing. Potwierdzone: URL uploadu (serwowany statycznie przez Apache jako /website/formularz/uploads/...) zwraca Content-Type: video/mp4 bez nagłówka nosniff, podczas gdy odpowiedzi MediaWiki nosniff mają (globalny

nagłówek zakomentowany w security.conf, MW dodaje własny). Rekomendacja: weryfikacja zawartości (dekodowanie obrazu), nosniff na ścieżce uploadów, katalog bez wykonywania PHP.

6.4 MEDIUM - Niezmoderowane uploady publicznie dostępne

```
@app.route('/uploads/<path:filename>')
def uploaded_file(filename):
    return send_from_directory('uploads', filename)
```

Route serwuje cały katalog uploads, w tym uploads/pending. Plik pobieralny pod /uploads/pending/.ext natychmiast po uploadzie, przed moderacją. Workflow pending/approved/rejected nie kontroluje dostępu do plików. Nazwa to uuid4 (nieprzewidywalna), więc nie pełne IDOR, ale treść niezmoderowana jest live zanim admin ją zobaczy. Path traversal na mitygowany przez safe_join we współczesnym Werkzeug. Rekomendacja: serwować tylko approved, pending poza web-rootem.

6.5 MEDIUM - Brak ochrony CSRF na akcjach admina

/admin/action//, /admin/delete/, /admin/delete_rejected to POST chronione wyłącznie Basic Auth. Przeglądarka dosyła Basic Auth automatycznie po zbuforowaniu. Brak tokenu CSRF, więc cross-site POST może wywołać akcję (kasowanie zgłoszeń i plików) w kontekście zalogowanego admina. Rekomendacja: token CSRF (Flask-WTF), rozważyć sesję zamiast Basic Auth.

6.6 INFO - Panel admina: sprawdzone, stored XSS niewykorzystywalny

Review admin.html: Jinja auto-escaping włączony, nickname i description escape'owane, original_name nierenderowane, s.url w href zablokowany walidacją wejścia (schemat http/https). Stored XSS niewykorzystywalny w obecnym kodzie. Uwaga defense-in-depth: href polega wyłącznie na walidacji przy zapisie, warto dodać drugą warstwę i rel="noopener noreferrer" przy target="_blank".

6.7 LOW - Bug logiczny: LINK_CACHE.clear() wyłącza anty-duplikat

```
LINK_CACHE[url] = now
LINK_CACHE.clear() # czyści cały cache tuż po wpisie
```

Cache czyszczony w całości zaraz po dodaniu wpisu, więc cooldown duplikatów linków nigdy nie działa. Defekt wyłączający własną kontrolę anti-spam. Usunąć .clear(), czyścić tylko wpisy starsze niż LINK_COOLDOWN.

6.8 LOW - Stan anty-abuse w pamięci procesu

RATE_LIMIT i LINK_CACHE to dicty w procesie. Pod gunicornem z wieloma workerami każdy ma własny stan, limit dzieli się przez liczbę workerów i resetuje przy restarcie. Wspólny store (Redis).

6.9 INFO - SQL sparаметryzowany oraz uwagi operacyjne

Wszystkie zapytania używają parametrów (con.execute(sql, (params))), brak SQL injection. init_db() tylko w zakomentowanym main, pod gunicornem nieuruchamiane. redirect('/formularz/thanks') hardcodeuje prefix proxy. Weryfikacja Turnstile z timeout 5 bez obsługi wyjątku, chwilowa niedostępność CF daje 500.

6.10 HIGH - Ekspozycja źródła i bazy Flaska przez statyczne serwowanie Apache

Aplikacja Flask leży fizycznie w docroot: /var/www/html/website/formularz/. Ruch aplikacyjny idzie przez reverse proxy (/formularz/), ale fizyczna ścieżka /website/formularz/ trafia w statyczne serwowanie Apache z pominięciem Flaska. Apache nie ma handlera dla .py ani .db, więc oddaje je jako pliki do pobrania.

Dowód:

```
$ curl -s -o /dev/null -w "%{http_code}" http://127.0.0.1/website/formularz/app.py
200
```

```
GET https://[REDACTED]/website/formularz/app.py
Status: 200 | Content-Type: text/x-python | Content-Length: 8466
```

Content-Type: text/x-python potwierdza, że Apache oddaje surowe źródło jako tekst. Osiągalne publicznie przez domenę (Cloudflare), bez znajomości origin IP.

Ujawnione: app.py z hasłem admina w plaintext i kluczem wgTurnstileSecretKey; submissions.db (SQLite) do pobrania jednym GET, potwierdzone (144 kB): nicki, opisy, realne IP zgłaszających, ścieżki plików, timestampy.

```
from flask import Flask, request, redirect, abort, jsonify, render_template, Response, send_from_directory
from urllib.parse import urlparse
import sqlite3
import os
import uuid
from datetime import datetime
from collections import defaultdict
from time import time
import hashlib
import requests

BASE_DIR = os.path.dirname(os.path.abspath(__file__))
DB_PATH = os.path.join(BASE_DIR, 'submissions.db')
UPLOAD_DIR = os.path.join(BASE_DIR, 'uploads', 'pending')

IMAGE_MIME = {'image/jpeg', 'image/png', 'image/webp'}
VIDEO_MIME = {'video/mp4', 'video/webm'}

IMAGE_EXT = {'jpg', 'jpeg', 'png', 'webp'}
VIDEO_EXT = {'mp4', 'webm'}

IMAGE_MAX = 10 * 1024 * 1024      # 10 MB
VIDEO_MAX = 100 * 1024 * 1024    # 100 MB

RATE_LIMIT = defaultdict(list)
LINK_CACHE = {}

MAX_SUBMISSIONS_PER_IP = 20
TIME_WINDOW = 600 # 10 minut

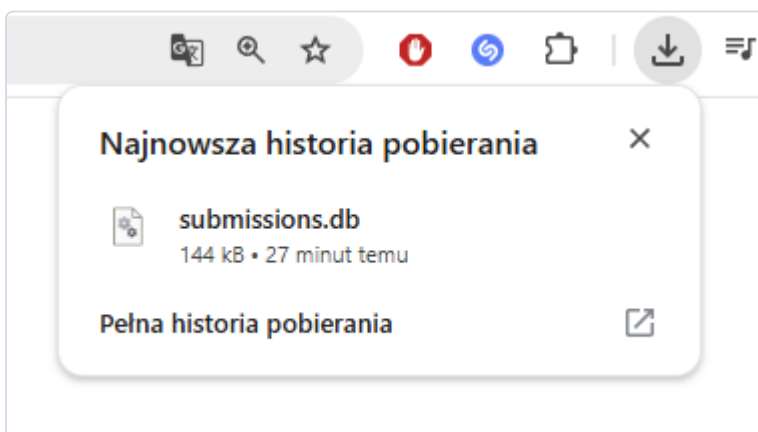
LINK_COOLDOWN = 3600 # 1 godzina

app = Flask(__name__)
app.config['MAX_CONTENT_LENGTH'] = 110 * 1024 * 1024

ADMIN_PASSWORD = "XXXXXXXXXX"

def check_auth(password):
    return password == ADMIN_PASSWORD

def authenticate():
```



Serwowanie statyczne jest niezależne od stanu procesu Flask. Wyłączenie gunicorna ubija endpointy /submit i /admin, ale pliki pozostają pobieralne. Dwa różne okna: sama aplikacja była aktywna ~2 miesiące, ale pliki (app.py,

submissions.db) były pobieralne od umieszczenia w docroot (katalog website datowany 27.12.2025) aż do migracji, czyli około 9 miesięcy - niezależnie od tego, czy proces Flask w danej chwili działał.

Łańcuch pięciu błędów: aplikacja WSGI w docroot, Apache serwuje źródło jako plik statyczny, w źródle hardcoded sekrety, publiczne ujawnienie hasła admina i klucza Turnstile, dostęp do panelu admina i bazy.

Działanie natychmiastowe: rotacja wgTurnstileSecretKey w Cloudflare (klucz żywy, współdzielony z produkcyjnym MediaWiki, publicznie serwowany). Rekomendacja: aplikacja WSGI poza docroot (np. /opt/formularz), reverse proxy zostaje. Jeśli musi zostać, twardy z Require all denied na kod aplikacji.

7. Warstwa serwera i ekspozycja

7.1 **INFO** - Apache + mod_php, wersja aktualna

PHP jako apache2handler (mod_php), kod wykonuje się jako www-data. Apache 2.4.58 wygląda staro, ale build 2026-07-06 wskazuje na świeże patchowanie (Ubuntu backportuje łatki zachowując numer). Nie finding. mod_remoteip niezaladowany, więc realne IP klientów przywraca aplikacja na poziomie WSGI (patrz 6.2).

7.2 **MEDIUM** - Origin osiągalny poza Cloudflare

Origin odpowiada bezpośrednio po IP z pominięciem Cloudflare.

Dowód:

```
curl -sKI -H "Host: [REDACTED]" https://[REDACTED_IP]/
HTTP/1.1 200 OK | Server: Apache/2.4.58 (Ubuntu) | pełna strona MediaWiki
```

Cała ochrona brzegowa (WAF, rate-limit, challenge, postawione na Cloudflare po ataku bota) jest do obejścia przez trafienie w IP origin zamiast w domenę. Origin IP jest znajdywalny (historia DNS, Shodan). Findingi 6.10 i 7.5 są tą drogą dostępne z pominięciem CF (poza tym że 6.10 potwierdzono też przez domenę). Rekomendacja: ograniczyć dostęp do origin wyłącznie do zakresów Cloudflare (firewall na porcie 443/80, allowlist IP Cloudflare).

7.3 **LOW** - Uprawnienia plików

Z listingu uprawnienia głównie root:root, z anomaliami www-data na images i bingo.html - do przeglądu pod kątem nadmiarowych uprawnień zapisu.

7.4 **LOW** - Content discovery, leftover

Z listingu leftovery: html_old/, html-backup/, raport.html, test.php, test.html - kandydaci do przeglądu (celowany fuzzing na .bak, .old, .swp, .git, .env).

7.5 **HIGH** - Directory listing włączony (Options Indexes)

Options Indexes FollowSymLinks (+ IndexOptions FancyIndexing) w [vhost].conf i 000-default.conf. Katalogi bez pliku index są listowane.

Dowód: https://[REDACTED]/website/ zwraca Index of /website przez Cloudflare (Port 443), listując formularz/ i upload/. Stopka autoindexu ujawnia publicznie Apache/2.4.58 (Ubuntu) Port 443.

Index of /website

Name	Last modified	Size	Description
 Parent Directory		-	
 formularz/	2026-05-05 20:12	-	
 upload/	2026-04-02 15:09	-	

Apache/2.4.58 (Ubuntu) Server at [REDACTED] Port 443

Wejście na /website/ ujawnia bezpośrednio app.py (hasło admina, 6.10) i pliki z /website/upload/ (7.10) dowolnemu odwiedzającemu, bez uwierzytelnienia, bez znajomości nazw. Zamienia 6.10 z "trzeba znać ścieżkę" na "każdy kto wpisze /website/". Rekomendacja: Options -Indexes globalnie.

7.6 **LOW** - Ujawnianie wersji serwera

ServerTokens OS daje nagłówek Server: Apache/2.4.58 (Ubuntu) (potwierdzone). ServerSignature On dokłada wersję na stronach błędów i stopkach autoindex (potwierdzone). Ustawić ServerTokens Prod, ServerSignature Off.

7.7 **LOW** - Brak ochrony przed clickjackingiem

Konfiguracja jawnie usuwa nagłówki: Header always unset X-Frame-Options, a jedyny CSP to frame-ancestors *. Brak ograniczenia ramkowania. Ustawić X-Frame-Options: SAMEORIGIN lub CSP frame-ancestors 'self'.

7.8 **INFO** - mod_status: sprawdzone, /server-status niewystawiony

status_module załadowany, ale /server-status zwraca 403 Forbidden przez domenę (ograniczony do localhost, jak default Ubuntu). mod_info niezaladowany. Nie finding.

7.9 **LOW** - wgServer na http:// oraz tryb SSL Cloudflare

wgServer = "http://[REDACTED]". Origin ma cert Let's Encrypt i odpowiada też po czystym HTTP. Jeśli tryb Cloudflare to Flexible, odcinek CF do origin nieszyfrowany. Ustawić wgServer na https, Cloudflare Full (strict), na nowym serwerze Origin Certificate.

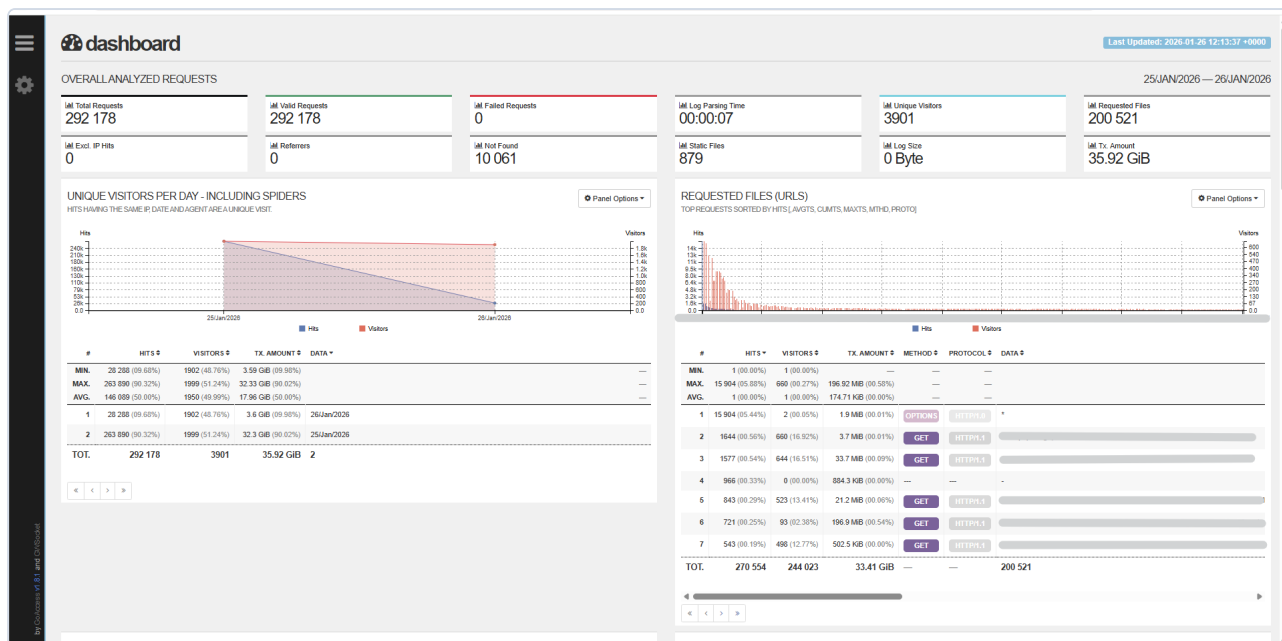
7.10 **MEDIUM** - Publicznie wystawione raporty GoAccess w /website/upload/

Ten sam root cause co 7.5, osobno z powodu odrębnego typu danych. /website/upload/ serwuje raporty GoAccess (raport-2026-*.html, raport-latest.html) oraz assety bingo (leftover, bez wartości). Potwierdzone: raporty zawierają panel z realnymi IP wszystkich odwiedzających (nie zanonimizowane). Zakres danych osobowych szerszy niż submissions.db: IP i historia ruchu całego serwisu (~200 osób dziennie przez miesiące). Panele Requested Files i Not Found ujawniają wewnętrzną strukturę URLi i ślady skanowania.

Index of /website/upload

Name	Last modified	Size	Description
Parent Directory		-	
bingo.html	2025-07-18 12:17	5.0K	
bingo_assets/	2025-07-29 18:19	-	
nowy.html	2025-09-29 07:21	904	
raport-2026-01-25.html	2026-01-25 11:05	1.0M	
raport-2026-01-26.html	2026-01-26 12:13	1.0M	
raport-2026-02-02.html	2026-02-02 21:55	952K	
raport-2026-04-02.html	2026-04-02 15:09	940K	
raport-latest.html	2026-04-02 15:09	940K	

Apache/2.4.58 (Ubuntu) Server at [REDACTED] Port 443



Rekomendacja: usunąć raporty z katalogu web-accessible, generować analitykę poza docroot, przy publicznej potrzebie za auth i z --anonymize-ip.

8. Zestawienie

#	Finding	Ważność
6.10	Ekspozycja źródła i bazy Flaska przez Apache	HIGH
7.5	Directory listing (Options Indexes)	HIGH
6.1	Hardcoded hasło admina	HIGH
2.1	Nieaktualny MediaWiki (1.43.0 vs 1.43.9)	HIGH
3.4	Upload SVG (stored XSS)	MEDIUM
3.5	ExternalData (SSRF)	MEDIUM
4.1	EmbedVideo 4.0.0 nieaktualne	MEDIUM
6.3	Upload: walidacja po stronie klienta	MEDIUM
6.4	Niezmoderowane uploady publiczne	MEDIUM
6.5	Brak CSRF na akcjach admina	MEDIUM
3.1	display_errors na produkcji	MEDIUM
7.2	Origin osiągalny poza Cloudflare	MEDIUM
7.10	Publiczne raporty GoAccess z IP odwiedzających	MEDIUM
3.2	Spalone klucze ReCaptcha w komentarzach	LOW
6.7	LINK_CACHE.clear() wyłącza anty-duplikat	LOW
6.8	Stan anty-abuse w pamięci procesu	LOW
7.3	Uprawnienia plików	LOW
7.4	Content discovery, leftover	LOW
7.6	Ujawnianie wersji serwera	LOW
7.7	Brak ochrony clickjacking	LOW
7.9	wgServer http:// oraz tryb SSL CF	LOW
3.3	Sekrety w LocalSettings, higiena backupów	INFO
3.6	Kontrole anty-spam po incydencie	INFO
5.1	Custom PHP (latest-video) czyste	INFO
6.2	Rate limiting sprawdzony, działa	INFO
6.6	Panel admina odporny na stored XSS	INFO
6.9	SQL sparametryzowany, uwagi operacyjne	INFO
7.1	Apache aktualny, mod_php	INFO
7.8	mod_status sprawdzony, niewystawiony	INFO

Dane osobowe: 6.10 (submissions.db, IP zgłaszających) i 7.10 (raporty GoAccess, IP wszystkich odwiedzających) obejmują realne dane osobowe wystawione publicznie. Publiczny write-up wymaga bezwzględnej anonimizacji.